

Compromised and Malicious Applications Investigation Playbook

Microsoft Learn field guide for application compromise investigations

Condensed, non-verbatim operational guide

Purpose	Quick-reference guide for identifying, investigating, containing, recovering from, and documenting malicious or compromised applications in a customer tenant.
Primary audience	SecOps analysts, incident responders, identity administrators, application administrators, tenant administrators, and IT operations teams.
Reference source	https://learn.microsoft.com/en-us/security/operations/incident-response-playbook-compromised-malicious-app
Generated	2026-07-03
Use note	This document is a condensed field guide based on Microsoft Learn guidance. Use the linked Microsoft Learn article as the authoritative source for the latest product-specific details, role requirements, portal paths, and command syntax.

Prepared for: Muataz Awad | Microsoft Security customer-facing readiness

1. Investigation objective and expected outcome

A compromised or malicious applications investigation should determine whether one or more applications in a customer tenant are malicious, compromised, over-permissioned, or being used by an attacker; what identities, permissions, and resources are involved; and what containment and recovery actions are required to reduce further risk.

Outcome statement

At the end of the investigation, the analyst should be able to answer: Which application or service principal is involved? Who owns it? What permissions, credentials, and access paths exist? Was the app used suspiciously? Which resources or users were impacted? What containment and recovery actions were completed?

2. At-a-glance workflow

Step	Phase	Focus
1	Confirm the application signal	Start from a user report, Microsoft Entra sign-in logs, Identity Protection detection, app governance alert, Defender/Sentinel incident, or other indication of suspicious app activity.
2	Identify the app and object relationships	Find the app registration, service principal, owners, credentials, redirect URIs, app roles, permissions, consent grants, and related workload identities.
3	Assess privilege and blast radius	Review risky permissions, consent model, admin consent history, application credentials, workload identity risk, data access, and privileged roles or ownership.
4	Correlate activity and evidence	Review Microsoft Entra audit/sign-in logs, app sign-ins, service principal activity, Defender for Cloud Apps/App Governance evidence, workload logs, and downstream resource access.
5	Contain and recover	Disable or restrict the application, revoke credentials/secrets/certificates, remove grants/assignments, rotate secrets, revoke sessions, and remediate affected users or resources.
6	Document and harden	Record timeline, evidence, affected objects, permissions, actions taken, and follow-up improvements for application governance and app lifecycle controls.

3. Readiness prerequisites

Identity Protection licensing: The Microsoft Learn source states that Microsoft Entra ID P2 is required to use Identity Protection signals.

Role access: The source calls out an account with at least the Security Administrator role.

Microsoft Graph capability: Investigators should be able to use Microsoft Graph Explorer and have some familiarity with Microsoft Graph API concepts.

Application audit concepts: Review application auditing concepts and ensure enterprise applications have owners set for accountability.

Consent and permissions concepts: Understand risky permissions, the consent model, and admin consent workflow; review app consent grant investigation concepts.

Workload identity and app governance concepts: Understand workload identity risk detections, anomaly detection alert investigation, application authentication methods, app management policies, and Defender for Cloud Apps app governance concepts.

Required tools: The source lists the Microsoft Entra Incident Response PowerShell Module and Microsoft Entra Toolkit as tools for an effective investigation.

Microsoft Learn prerequisite highlight

The Microsoft Learn article says the playbook is intended to help investigate malicious attacks on one or more applications in a customer tenant, and includes prerequisites, workflow, investigation steps, containment steps, recovery steps, and references.

4. Investigation checklist

Initial triage and object inventory

- ☐ Capture the initial signal: user report, sign-in log, Identity Protection detection, Defender/Sentinel incident, or app governance alert.
- ☐ Identify the application ID, service principal ID, display name, publisher, owners, tenant presence, and creation/modified dates where available.
- ☐ Preserve evidence before disabling/deleting objects or removing grants.

Application configuration review

- ☐ Review app registration and enterprise application properties, owners, redirect URIs, credentials, certificates, secrets, and federated credentials.
- ☐ Review API permissions, app roles, OAuth grants, app role assignments, admin consent/user consent evidence, and risky permissions.
- ☐ Determine whether the application has workload identity risk signals or unusual service principal sign-in activity.

Activity and blast-radius analysis

- ☐ Review Microsoft Entra audit logs and sign-in logs for application, service principal, and owner activity.
- ☐ Correlate application activity with mailbox, file, SharePoint, Graph, cloud app, endpoint, or resource logs as available.
- ☐ Identify users, groups, resources, and administrative roles affected by the application or its permissions.

Containment and recovery

- ☐ Disable or restrict the app/service principal if risk is confirmed or likely.
- ☐ Remove suspicious grants, app role assignments, credentials, secrets, or certificates where appropriate.
- ☐ Rotate credentials and update dependent services when legitimate apps were compromised.
- ☐ Remediate affected identities, including password reset, MFA/security info review, and session revocation where compromise is suspected.

Closure and governance improvement

- ☐ Document timeline, evidence, impacted objects, permissions, containment actions, and recovery status.
- ☐ Assign or validate application owners and improve periodic review of high-risk permissions and credentials.
- ☐ Update monitoring for application changes, risky consent, workload identity risk, service principal sign-ins, and suspicious API activity.

5. Detailed investigation guidance

5.1 Start with the source signal

- Use the available indication as the starting point: user report, sign-in logs, Identity Protection detection, Defender/Sentinel incident, or another suspicious app signal.
- Capture object IDs and timestamps early so evidence is consistent across Microsoft Entra, Defender, Sentinel, and workload logs.
- Preserve evidence before making destructive changes such as deleting app objects, removing grants, or rotating credentials.

5.2 Identify the app registration and service principal

- Locate the application registration and enterprise application/service principal in the tenant.
- Review owners, credentials, certificates, secrets, redirect URIs, publisher and verified publisher information, API permissions, and app role assignments.
- Confirm whether the object is expected, has accountable owners, and aligns with a documented business purpose.

5.3 Assess permissions and access paths

- Review delegated permissions, application permissions, app roles, OAuth grants, and admin/user consent evidence where available.
- Prioritize permissions that allow broad directory, mail, files, SharePoint, Graph, or administrative access.
- Check whether workload identity controls, app governance, or Defender for Cloud Apps provide additional context.

5.4 Correlate application activity and downstream impact

- Review Microsoft Entra audit logs and sign-in logs for app and service principal activity.
- Correlate with downstream access to mailboxes, files, SharePoint sites, APIs, cloud apps, endpoints, and administrative actions where logs are available.
- Determine whether observed activity is consistent with expected app behavior or suggests malicious access, persistence, data exposure, or lateral movement.

5.5 Contain, recover, and harden

- Disable the app/service principal or restrict access when risk is confirmed or likely, while following customer change-control and evidence preservation requirements.
- Remove suspicious credentials, grants, app role assignments, or admin consent; rotate credentials for legitimate apps that were compromised.
- After recovery, improve governance through app ownership, least-privilege permission review, consent governance, credential hygiene, workload identity monitoring, and periodic access reviews.

6. Handy command and query starting points

Reminder

Validate command syntax and permissions against the latest Microsoft Learn docs before running in a customer tenant. Scope permissions and use least privilege.

Use case	Example / location	Why it matters
----------	--------------------	----------------

Install incident response tooling	Install and import Microsoft Entra Incident Response PowerShell Module / Microsoft Entra Toolkit according to the official documentation.	The Microsoft Learn article lists these tools for an effective investigation.
Find application objects	Use Microsoft Graph / Entra portal to locate app registrations and service principals by appId, objectId, or displayName.	Needed to connect the reported app to its tenant objects and permissions.
Review audit events	AuditLogs where TargetResources has "<app-id-or-name>"	KQL starting point for app-related audit activity; validate table/source availability.
Review service principal sign-ins	ServicePrincipalSignInLogs where AppId == "<app-id>"	KQL starting point for suspicious app/service principal activity; validate table/source availability.
Review consent events	AuditLogs where OperationName has "Consent"	Useful starting point for consent-related activity when audit logs are available.

7. Evidence matrix

Question	Helpful evidence sources
What application is involved?	App registration, service principal, appId/objectId, display name, publisher, owners, tenant presence
Who owns or administers it?	Application owners, audit logs, administrative actions, ownership history where available
What access does it have?	API permissions, app role assignments, OAuth grants, admin/user consent evidence, risky permissions
How was it authenticated?	Credentials, certificates, secrets, federated credentials, service principal sign-ins
Was it used suspiciously?	App/service principal sign-ins, audit logs, workload logs, Defender/Sentinel/App Governance evidence
What resources were impacted?	Mailbox/file/SharePoint/Graph/cloud app/resource logs and downstream access evidence
Was risk contained?	Disabled app/service principal status, removed grants, deleted/rotated credentials, session/user remediation evidence

8. Closure notes template

- ☐ Incident summary: suspected compromised or malicious application, source signal, and affected tenant objects.
- ☐ Timeline: application creation/modification, consent or credential changes, suspicious sign-ins, discovery, containment, and recovery completion.
- ☐ Scope: application IDs, service principal IDs, owners, permissions, users/groups/resources affected, and workload identity risks.
- ☐ Evidence reviewed: Microsoft Entra audit/sign-in logs, app/service principal sign-ins, permissions/grants, app governance signals, Defender/Sentinel evidence, and workload logs.
- ☐ Verdict: malicious, compromised legitimate app, over-permissioned/suspicious app, benign, or inconclusive with rationale.
- ☐ Actions completed: app disabled/restricted, credentials removed/rotated, grants revoked, owners updated, users remediated, monitoring added.
- ☐ Follow-up recommendations: app owner accountability, high-risk permission review, consent governance, credential rotation program, workload identity risk monitoring, periodic access reviews.

9. Authoritative sources

Primary Microsoft Learn article: [Compromised and malicious applications investigation | Microsoft Learn](#)

Related Microsoft Learn playbook referenced by the source: [App consent grant investigation | Microsoft Learn](#)

This field guide does not replace the official articles. Always reference Microsoft Learn for the latest workflow diagrams, role/permission details, portal paths, and command syntax.